Security Requirements Specification (SRSec)

Web Based ML Model Evaluator

Version 1.0 (draft for review) | October 2026

Item	Detail
Project	Web Based ML Model Evaluator (Software Engineering mini-project)
Course code	UE23CS341A, Department of CSE
Team members and registration numbers	[To be completed]
Faculty guide	[To be completed]
Reference document	Software Requirements Specification of the project (uploaded version)
Status	Requirements, threat model, and test cases defined; security testing not yet performed

Revision history

Version	Date	Description	Author
1.0	October 2026	Initial version	[To be completed]

Table of Contents

1. Introduction
2. Security Objectives
3. Assets to Protect
4. Threat Model
5. Security Functional Requirements
6. Security Non-Functional Requirements

7. Security Controls and Implementation Guidelines
8. Security Test Cases
9. Security Risk Assessment
10. Security Assumptions, Constraints, and Limitations
11. Traceability Matrix

Appendix A. SRS Reference Index

Appendix B. References

1. Introduction

1.1 Purpose

This document specifies the security requirements, threat model, security controls, security test cases, and risk assessment for the Web Based ML Model Evaluator (“the System”). It extends the project Software Requirements Specification (SRS) and does not change any of its functional requirements. Security test cases use the prefix SEC-TC so that they do not collide with the functional test plan.

1.2 Scope

The scope covers every function described in the SRS (SRS-FR01 to SRS-FR10) and the components the SRS names: web frontend, REST API, relational database, dataset and artifact storage, and the machine learning training and evaluation components where they process user data. Deployment is on a single server (SRS-SR05). Exclusions are listed in Section 10.3.

1.3 Project overview

Users register and log in, upload CSV datasets, preview and preprocess them, choose a target column and a train-test split, train classification or regression models, evaluate and compare the results, and download trained models and PDF reports. The SRS leaves several implementation choices open; Section 7.1 lists them.

1.4 Intended audience

Course evaluators, development team members, the testers who execute Section 8, and anyone who maintains the System later.

1.5 Conventions and sources of truth

- The SRS is the primary source. The uploaded SRS does not assign identifiers to its requirements, so this document refers to them as SRS-FR01 to SRS-FR10, SRS-NFR01 to SRS-NFR10, SRS-UR01 to SRS-UR10, SRS-SR01 to SRS-SR09, and SRS-DR01 to SRS-DR10, in the order they appear. Appendix A lists them. Adding these identifiers to the SRS before submission is recommended so that the references can be checked directly.
- Each security requirement carries one source label. SRS-EXT means the requirement extends the cited SRS items with measurable security criteria without contradicting them. REC means the requirement is a security recommendation that the SRS does not state; any cited SRS items give context only.
- “Shall” denotes a mandatory requirement. “Should” denotes a recommendation.
- Values marked “proposed” are targets set by this document. The SRS does not quantify the upload size limit (SRS-NFR07), the session policy, or the password policy. The team must confirm these values before implementation (Section 10.4).
- Identifier prefixes: SEC-FR (security functional requirement), SEC-NFR (security non-functional requirement), SEC-TC (security test case), T (threat), A (asset), R (risk), AS (assumption), CN (constraint), LM (limitation).

1.6 Definitions and abbreviations

Term	Meaning
BOLA / IDOR	Broken object-level authorization / insecure direct object reference
CORS	Cross-origin resource sharing
CSP	Content Security Policy
CSRF	Cross-site request forgery
CSV	Comma-separated values
DoS	Denial of service
HttpOnly, SameSite, Secure	Cookie attributes that limit script access, cross-site sending, and transmission over plain HTTP
ORM	Object-relational mapper
PII	Personally identifiable information

Term	Meaning
REST	Representational state transfer
SQLi	SQL injection
TLS	Transport Layer Security; HTTPS uses TLS
UUID	Universally unique identifier
XSS	Cross-site scripting

2. Security Objectives

The objectives below define what protection means for this System. Each objective is traced to requirements in Sections 5 and 6.

Objective	Meaning for this System	Principal requirements
Confidentiality	A user's datasets, models, results, reports, and credentials are visible only to that user and to the System's own processes.	SEC-FR-02, 09 to 11, 22; SEC-NFR-01, 02, 04
Integrity	Stored datasets, models, metrics, and records change only through authorized actions, and metric values are computed by the server.	SEC-FR-12, 16, 18, 23; SEC-NFR-03
Availability	The System remains usable for its intended group of users, and malformed or excessive input from one user cannot stop the service for others.	SEC-FR-17, 24, 28; SEC-NFR-05
Authentication	Each request is attributable to a verified user, and credentials and sessions resist guessing, theft, and fixation.	SEC-FR-01 to 08; SEC-NFR-02, 04

Objective	Meaning for this System	Principal requirements
Authorization	Every request for a user's object is checked on the server against ownership.	SEC-FR-09 to 13, 22, 29
Accountability and auditability	Security-relevant events are recorded so that they can be reconstructed, without recording secrets.	SEC-FR-25; SEC-NFR-11

3. Assets to Protect

Classification: Restricted means compromise enables impersonation or control of the System. Confidential means the asset contains or derives from user data. Internal means operational information without user data or secrets.

ID	Asset	Description	Classification
A1	User credentials	Login identifiers and password hashes	Restricted
A2	User accounts	Account records and ownership links	Confidential
A3	Session credentials	Session identifiers or tokens	Restricted
A4	Uploaded datasets	Raw CSV files, which may contain personal or institutional data	Confidential
A5	Dataset metadata	File name, row and column counts, column names, data types, sample values	Confidential
A6	User configurations	Preprocessing options, target column, split ratio, algorithm choice	Confidential
A7	Trained model artifacts	Serialized models, which can encode information about training data	Confidential
A8	Evaluation results	Metrics, confusion matrices, training status, comparisons	Confidential
A9	Evaluation reports	PDF reports summarizing datasets, models, and metrics	Confidential

ID	Asset	Description	Classification
A10	Database records	Relational records for A1, A2, A5, A6, and A8, including storage pointers	Confidential
A11	API endpoints	Interfaces through which all user data is accessed (SRS-SR08)	Internal
A12	Secrets and configuration	Framework secret key, database credentials, any signing key	Restricted
A13	Application and security logs	Operational and security event records	Internal
A14	Server and dependencies	Runtime environment, third-party libraries, compute resources	Internal

4. Threat Model

4.1 Method and trust boundaries

Threats were identified per asset. The OWASP Top 10 (2021) and OWASP API Security Top 10 (2023) served as checklists, and the STRIDE categories (spoofing, tampering, repudiation, information disclosure, denial of service, and elevation of privilege) were used to check coverage. Each threat is linked to a Common Weakness Enumeration (CWE) entry. Section 9 rates the threats.

The trust boundaries are:

- TB-1: browser to web server. The client is untrusted, and all input is treated as hostile.
- TB-2: web server to relational database.
- TB-3: web server to dataset and artifact storage.
- TB-4: web server to the ML training and evaluation process, whether in-process or in a separate worker.
- TB-5: client network. College Wi-Fi and the public internet are untrusted.

4.2 Threat register

ID	Threat (CWE)	Assets	Possible impact	Mitigation	Requirements
T-01	Access to protected functions without authentication (CWE-306)	A4 to A9	Any visitor reads or changes user data	Deny by default; authentication check on every data endpoint	SEC-FR-09, 29
T-02	Brute-force and credential-stuffing attacks on login (CWE-307)	A1, A2	Account takeover and exposure of all of the user's data	Uniform error responses, throttling, length-based password policy	SEC-FR-01, 03, 04
T-03	Credentials and session cookies intercepted on an untrusted network (CWE-319)	A1, A3	Impersonation of the user	HTTPS for non-local deployment; Secure cookies; no secrets in URLs	SEC-NFR-02; SEC-FR-06; SEC-NFR-04
T-04	Session fixation, hijacking, and sessions that remain valid after logout (CWE-384, CWE-613)	A3	Unauthorized access with an old or stolen session	New session at login; idle and absolute expiry; server-side logout	SEC-FR-05, 07, 08
T-05	Cross-user access by changing an object identifier (BOLA; CWE-639)	A4 to A9	Disclosure or alteration of other users' data, contrary to SRS-NFR08	Ownership check on every object request; HTTP 404 for other users' objects; non-sequential identifiers	SEC-FR-10, 11, 12
T-06	Malicious or malformed CSV content: binary data disguised as CSV, invalid encoding, oversized fields, excessive dimensions (CWE-20)	A4, A5, A13, A14	Crash, memory exhaustion, or misleading results	Content-based validation; size and structure limits; plain-language errors	SEC-FR-16, 17, 24
T-07	Path traversal and overwrite through user-supplied file names (CWE-22, CWE-434)	A4, A7, A9, A12	Files read or written outside storage; another user's file replaced	Server-generated storage names; original names kept as metadata only; no overwrite	SEC-FR-18, 22

ID	Threat (CWE)	Assets	Possible impact	Mitigation	Requirements
T-08	Resource exhaustion and denial of service through large uploads, concurrent training, or long jobs (CWE-400)	A11, A14	Service unavailable to other users (SRS-NFR03)	Upload limits; concurrency and time limits; request rate limits	SEC-FR-17, 28; SEC-NFR-05
T-09	SQL injection through identifiers, form fields, or column names (CWE-89)	A10 and all database-backed assets	Disclosure, modification, or deletion of records; authentication bypass	Parameterized queries or ORM; least-privilege database account	SEC-FR-21
T-10	Cross-site scripting through user-controlled text such as column names, cell values, and dataset names (CWE-79)	A5, A8, A9, A11	Script execution in the user's browser; session theft	Output encoding; no raw HTML insertion; Content Security Policy	SEC-FR-19, 20; SEC-NFR-09
T-11	Cross-site request forgery on state-changing requests (CWE-352)	A4, A6, A8, A9	A visited malicious page uploads, trains, or deletes data in the user's session	Anti-CSRF tokens for cookie sessions; SameSite cookies	SEC-FR-30; SEC-FR-06
T-12	Excessive data in API responses, unsupported methods, and permissive cross-origin policy (CWE-200, CWE-942)	A2, A10, A11	Disclosure of internal fields, storage paths, or other users' identifiers	Response allow-lists; method allow-lists; CORS allow-list	SEC-FR-29, 31
T-13	Information disclosure through error messages (CWE-209)	A10, A12, A14	Stack traces, SQL text, or paths help an attacker plan further attacks	Generic server errors; detailed information in server logs only	SEC-FR-24
T-14	Credentials or data written to logs, or logs read or altered (CWE-532)	A1, A3, A4, A13	Credentials or data exposed through the log store	Redaction; restricted log access; retention limit	SEC-FR-25; SEC-NFR-04, 11

ID	Threat (CWE)	Assets	Possible impact	Mitigation	Requirements
T-15	Unauthorized access to trained models and reports, including by direct file path (CWE-552)	A7, A9	Disclosure of models and reports	Storage outside the web root; authorized download endpoints only; restrictive permissions	SEC-FR-22, 10; SEC-NFR-01
T-16	Unsafe deserialization of a model artifact that was replaced or tampered with (CWE-502)	A7, A14	Arbitrary code execution on the server	Digest verification before load; load only System-created artifacts; no user-supplied model files	SEC-FR-23, 15; SEC-NFR-03
T-17	Known vulnerabilities in third-party libraries and frameworks (CWE-1104)	A14 and all assets	Exploitation through a publicly known vulnerability	Version pinning; vulnerability scanning; timely updates	SEC-NFR-08
T-18	Security misconfiguration and secret exposure: debug mode, hard-coded or default secrets, exposed configuration files (CWE-16, CWE-798)	A12, A13, A14	Session forgery, database compromise, information disclosure	Secrets from environment; debug off; blocked configuration paths; security headers	SEC-FR-27; SEC-NFR-07, 09
T-19	Incomplete deletion and excessive retention of user data (CWE-459)	A4, A7, A8, A9, A10	Deleted data remains on disk; privacy exposure over time	Delete records and files together; scheduled retention cleanup	SEC-FR-26; SEC-NFR-06
T-20	CSV formula injection in exported files (CWE-1236)	A8	A spreadsheet formula runs when an export is opened	Neutralize formula-leading characters in exports	SEC-FR-32

5. Security Functional Requirements

Each requirement is written to be testable. The Verified by column refers to Section 8. Source labels are defined in Section 1.5.

5.1 Registration, login, and credential protection

ID	Requirement	Source	Verified by
SEC-FR-01	The System shall accept a registration only if the login identifier has 3 to 30 characters from letters, digits, underscore, dot, and hyphen, and the password has 8 to 128 characters. Composition rules, such as mandatory symbols, shall not be imposed. The length limits follow NIST SP 800-63B, Section 5.1.1.2 (minimum 8 characters; at least 64 accepted).	SRS-EXT: SRS-UR01	SEC-TC-01, 02, 03
SEC-FR-02	Passwords shall be stored only as salted hashes produced by an established adaptive hash function (Argon2id, bcrypt, or scrypt) or by the password hasher built into the selected framework. Plaintext passwords shall never be written to storage, logs, or responses.	SRS-EXT: SRS-UR01	SEC-TC-04
SEC-FR-03	A failed login shall return HTTP 401 with the same message for an unknown identifier and for a wrong password. For an unknown identifier the System shall still perform a password hash computation, so that response time does not reveal whether the account exists. Proposed target: median difference below 50 ms over 20 trials.	REC	SEC-TC-05

ID	Requirement	Source	Verified by
SEC-FR-04	After five consecutive failed logins for one identifier within 15 minutes, further attempts for that identifier shall be refused with HTTP 429 for 15 minutes (proposed). Login requests from one source address shall be limited to 20 per minute (proposed), and the limit shall be raised if many users share one campus address (SRS-NFR03). Throttling is used instead of permanent lockout to prevent targeted lockout of legitimate users.	REC (context: SRS-NFR03)	SEC-TC-06

5.2 Sessions and logout

ID	Requirement	Source	Verified by
SEC-FR-05	On successful login, the System shall issue a new session credential from a cryptographically secure random generator with at least 128 bits of entropy, and shall invalidate any credential issued before login.	SRS-EXT: SRS-UR01	SEC-TC-07
SEC-FR-06	With cookie-based sessions, the session cookie shall carry HttpOnly, SameSite=Lax or SameSite=Strict, and Secure (when served over HTTPS). With token-based authentication, the design shall document where the token is stored and the resulting script-exposure risk, and tokens shall never appear in URLs.	REC	SEC-TC-08
SEC-FR-07	Sessions shall expire after 30 minutes of inactivity or 8 hours after login, whichever occurs first (proposed).	REC	SEC-TC-09

ID	Requirement	Source	Verified by
SEC-FR-08	Logout shall invalidate the server-side session or token. A later request that presents the old credential shall receive HTTP 401.	REC	SEC-TC-10

5.3 Authorization and user isolation

ID	Requirement	Source	Verified by
SEC-FR-09	Every endpoint that reads, creates, changes, or deletes user data shall reject requests without a valid session with HTTP 401 and shall return no user data. Only registration, login, and static page resources are public.	SRS-EXT: SRS-UR01	SEC-TC-11
SEC-FR-10	For every request that names a dataset, model, result, or report by identifier, the server shall confirm that the requester owns the object before reading, changing, or deleting it. A request for another user's object shall return HTTP 404, identical to a request for a nonexistent object.	SRS-EXT: SRS-NFR08, SRS-UR01	SEC-TC-12
SEC-FR-11	Dataset lists, model lists, dashboards, and comparisons (SRS-FR09) shall include only the requester's objects. A comparison request containing any model identifier that the requester does not own shall be rejected in full.	SRS-EXT: SRS-FR09, SRS-NFR08	SEC-TC-13

ID	Requirement	Source	Verified by
SEC-FR-12	Metric values, confusion matrices, and training status shall be computed and stored by the server. Metric values supplied by the client shall be ignored or rejected.	SRS-EXT: SRS-FR08, SRS-DR05	SEC-TC-14
SEC-FR-13	The System shall define one end-user role. No administrative or cross-user function shall exist unless added by a documented change to this specification, and any such function shall be enforced on the server.	REC (context: the SRS defines one user actor)	SEC-TC-15

5.4 Input validation and file handling

ID	Requirement	Source	Verified by
SEC-FR-14	Every parameter received by the server (object identifiers, split ratio, target column name, preprocessing options, algorithm identifier) shall be validated for type, range, and allow-list membership. Invalid values shall be refused with HTTP 400 and a plain-language message. Client-side checks supplement, but do not replace, this validation.	SRS-EXT: SRS-FR03 to SRS-FR06	SEC-TC-16
SEC-FR-15	Algorithm identifiers shall resolve only through a server-side registry of supported algorithms. The System shall never import, instantiate, or execute a class, module path, or expression derived from user input.	SRS-EXT: SRS-FR06, SRS-NFR10	SEC-TC-17

ID	Requirement	Source	Verified by
SEC-FR-16	An upload shall be accepted only if its name ends in .csv, its content decodes as UTF-8 (or an encoding documented in the design), its leading bytes are not a known binary signature (ZIP 50 4B 03 04; PDF 25 50 44 46; OLE2 D0 CF 11 E0; ELF 7F 45 4C 46; MZ header 4D 5A), and it parses as delimited text with a consistent column count. An extension check alone is insufficient. Failures return the plain-language message required by SRS-UR10.	SRS-EXT: SRS-DR01, SRS-FR01, SRS-NFR04	SEC-TC-18
SEC-FR-17	The System shall refuse uploads larger than 10 MB (10,485,760 bytes; proposed), checked before the full body is buffered (HTTP 413). It shall refuse datasets with more than 100,000 rows or 500 columns, or with fields longer than 1,000 characters (all proposed), and datasets with fewer rows than the minimum in SRS-DR09 (20 rows, the SRS example value), with HTTP 400 and a plain-language message.	SRS-EXT: SRS-NFR07, SRS-DR09	SEC-TC-19
SEC-FR-18	Uploaded datasets and artifacts shall be stored under server-generated identifiers (for example, UUID version 4) in a directory outside the web root. The user-supplied file name shall be stored only as metadata and shall never be used to build a filesystem path. Stored files shall never be overwritten.	SRS-EXT: SRS-SR04	SEC-TC-20

ID	Requirement	Source	Verified by
SEC-FR-19	All user-supplied text (column names, cell values in the preview, dataset names, file names, and any input echoed in a message) shall be rendered as text, not as markup. The frontend shall not insert such values through raw HTML interfaces.	SRS-EXT: SRS-FR02, SRS-UR03, SRS-DR10	SEC-TC-21
SEC-FR-20	PDF reports shall render user-supplied strings as literal text, without interpreting markup or control characters that alter the document.	SRS-EXT: SRS-FR10	SEC-TC-22
SEC-FR-21	Database access shall use parameterized queries or the query interface of the selected ORM. No SQL statement shall be built by concatenating or formatting user input.	SRS-EXT: SRS-SR04	SEC-TC-23

5.5 Downloads, artifacts, and integrity

ID	Requirement	Source	Verified by
SEC-FR-22	Model and report downloads shall: (a) require an authenticated session (SEC-FR-09); (b) verify ownership (SEC-FR-10); (c) resolve files only through a database record with status completed, never through a client-supplied path; and (d) send Content-Type application/octet-stream for models or application/pdf for reports, X-Content-Type-Options: nosniff, and Content-Disposition: attachment with a server-generated file name containing only letters, digits, underscores, and hyphens.	SRS-EXT: SRS-FR10, SRS-UR08, SRS-SR09	SEC-TC-24, 25
SEC-FR-23	Each model artifact shall have a SHA-256 digest recorded when it is created. The digest shall be verified before any download or load. An artifact whose digest does not match shall not be loaded or served, and the mismatch shall be logged.	SRS-EXT: SRS-SR09	SEC-TC-26
SEC-FR-24	Unexpected errors shall return HTTP 500 with a generic message, such as “An unexpected error occurred. Please try again.” Responses shall not contain stack traces, SQL text, file paths, library names, or version numbers; these details go to the server log only. Known input and file errors shall return plain-language messages that identify the problem, such as “The target column was not found”, without exposing internals.	SRS-EXT: SRS-NFR04, SRS-UR10	SEC-TC-27

5.6 Logging, deletion, secrets, and abuse controls

ID	Requirement	Source	Verified by
SEC-FR-25	The System shall record security-relevant events with timestamp, user identifier (or “anonymous”), source address, action, object identifier, and outcome. Events include registration; login success and failure; lockout; logout; session expiry; authorization denial; upload accepted or rejected; training started, completed, or failed; download; deletion; and integrity failure. Log entries shall never contain passwords, password hashes, session credentials, or dataset contents.	REC (context: the SRS is silent on logging)	SEC-TC-28
SEC-FR-26	When a user deletes a dataset or result (SRS-UR09), the System shall remove the database records and every associated stored file (dataset, model artifact, report), and shall prevent later access through the application. Deleting a dataset shall also delete its models, results, and reports. Each deletion shall be logged under SEC-FR-25.	SRS-EXT: SRS-UR09, SRS-SR04	SEC-TC-29
SEC-FR-27	Secrets (framework secret key, database credentials, and any signing key) shall be supplied through environment variables or a secrets file excluded from version control. Secrets shall not appear in source code, client-side code, HTML, API responses, or logs.	REC	SEC-TC-30

ID	Requirement	Source	Verified by
SEC-FR-28	The System shall run at most one training job per user and at most two system-wide (proposed; to be set according to the hardware in SRS-SR07). Each job shall have a time limit of 10 minutes (proposed); a job that exceeds it shall be terminated and reported as failed in plain language. Requests beyond the limits shall receive HTTP 429 or be queued with a visible status (SRS-UR05).	SRS-EXT: SRS-FR07, SRS-NFR03, SRS-SR07	SEC-TC-31
SEC-FR-29	Each endpoint shall accept only the HTTP methods defined in the API specification; other methods shall receive HTTP 405. Responses shall include only the fields that the frontend uses, and shall never include password hashes, internal storage paths, or other users' identifiers.	REC (context: SRS-SR08)	SEC-TC-32

5.7 Cross-site and export controls

ID	Requirement	Source	Verified by
SEC-FR-30	With cookie-based sessions, every state-changing request (POST, PUT, PATCH, DELETE) shall carry an anti-CSRF token that the server validates, in addition to the cookie attributes in SEC-FR-06. With header-based token authentication, the design shall document why CSRF does not apply.	REC (context: SRS-SR08)	SEC-TC-33

ID	Requirement	Source	Verified by
SEC-FR-31	If the frontend and backend have different origins, the backend shall allow cross-origin requests only from the configured frontend origin, and shall never send a wildcard origin for requests that carry credentials.	REC (context: SRS-SR03, SRS-SR08)	SEC-TC-34
SEC-FR-32	If the System exports any CSV file, cell values beginning with =, +, -, @, tab, or carriage return shall be prefixed with an apostrophe or otherwise neutralized. This requirement applies only if a CSV export is implemented; the SRS requires a PDF report (SRS-FR10).	REC (context: SRS-UR08)	SEC-TC-35

5.8 Consistency with the SRS

SRS item	Possible tension	Resolution
SRS-UR09 (cleanup so the dashboard is not cluttered)	Cleanup could be implemented by hiding entries, which leaves files on disk	SEC-FR-26 requires deletion of records and files. This satisfies SRS-UR09 and does not contradict it.
SRS-UR10 (plain-language error messages)	Messages must be informative, but internal details must not be exposed	Messages describe the user's input, such as a missing column. They never describe internals (SEC-FR-24).
SRS-NFR03 (multiple users)	Login throttling may affect several classmates who share one campus address	The per-address limit is set to accommodate shared addresses; the per-identifier limit does most of the work (SEC-FR-04).

SRS item	Possible tension	Resolution
SRS-FR10 (download trained model file)	Serving model files creates risks of tampering and unsafe loading	Downloads are authorized and digest-checked (SEC-FR-22, 23). The System never loads user-supplied model files (SEC-FR-15, 23).

6. Security Non-Functional Requirements

ID	Requirement	Source	Verified by
SEC-NFR-01	Datasets, model artifacts, and reports shall be readable and writable only by the service account that runs the application (for example, mode 0600 for files and 0700 for directories on POSIX systems). Encryption at rest is optional; if used, it shall rely on an established library, with keys held outside the source code.	SRS-EXT: SRS-SR04	SEC-TC-36
SEC-NFR-02	For any deployment other than the local host, all client–server traffic shall use HTTPS with TLS 1.2 or later, and plain HTTP shall be redirected to HTTPS or refused. For a localhost-only demonstration, TLS is not required; this exception is recorded in LM-08.	REC (context: SRS-SR05)	SEC-TC-37
SEC-NFR-03	Datasets, model artifacts, and evaluation results shall be verified against SHA-256 digests recorded at creation before use. A mismatch shall stop the operation, return a plain-language error, and be logged.	SRS-EXT: SRS-NFR06, SRS-DR03	SEC-TC-38

ID	Requirement	Source	Verified by
SEC-NFR-04	Passwords, session credentials, and tokens shall not appear in URLs, query strings, redirect targets, or logs.	REC (context: SRS-UR01)	SEC-TC-39
SEC-NFR-05	While one training job runs on a dataset at the maximum permitted size, 95% of home-page requests shall complete within 2 seconds (proposed) from a client on the target network. The concurrency limits in SEC-FR-28 apply.	SRS-EXT: SRS-NFR01, SRS-NFR03	SEC-TC-40
SEC-NFR-06	Uploaded datasets, artifacts, and reports shall be retained only while the owner keeps them, and for no more than 90 days after the owner's last login (proposed). A scheduled job shall remove expired items and their records and shall log each removal. The upload page shall state that datasets should not contain personal information.	SRS-EXT: SRS-UR09	SEC-TC-41
SEC-NFR-07	Deployed instances shall run with debug mode disabled, behind a production-grade application server rather than the framework's development server, with directory listing disabled and default credentials removed.	REC (context: SRS-SR05)	SEC-TC-42
SEC-NFR-08	Third-party dependencies shall be pinned to explicit versions in a lock file. A vulnerability scan (for example, pip-audit for Python packages or npm audit for JavaScript packages) shall run before submission and before each release. High and critical findings shall be fixed or documented with a justification.	SRS-EXT: SRS-SR01, SRS-SR02	SEC-TC-43

ID	Requirement	Source	Verified by
SEC-NFR-09	HTML and API responses shall include X-Content-Type-Options: nosniff; a Content-Security-Policy that restricts scripts to the application's own origin; X-Frame-Options: DENY or the equivalent frame-ancestors directive; and a Referrer-Policy of no-referrer or strict-origin-when-cross-origin.	REC (context: SRS-FR02)	SEC-TC-44
SEC-NFR-10	Security controls (authentication, ownership checks, validation, output encoding, and logging) shall be implemented in shared modules, middleware, or decorators separate from the ML logic, so that new endpoints and algorithms inherit them without duplicated security code.	SRS-EXT: SRS-NFR05, SRS-NFR10	SEC-TC-45
SEC-NFR-11	Security logs shall not be reachable through the web application, shall be readable only by the service account and the maintainers, and shall be retained for 30 days (proposed).	REC	SEC-TC-46
SEC-NFR-12	Security controls shall behave consistently in the latest versions of Chrome, Firefox, and Edge, including cookie attributes, Content Security Policy enforcement, and CSRF handling.	SRS-EXT: SRS-SR06, SRS-NFR09	SEC-TC-47

7. Security Controls and Implementation Guidelines

7.1 Stack options permitted by the SRS

The SRS leaves the following choices open. The security requirements apply to every option, and the team records its choice in the design document.

Layer	Options named in the SRS	Security notes
Backend	Flask or Django (SRS-SR01)	Django includes CSRF protection, session management, and password hashing. With Flask, CSRF protection and login sessions need extension libraries, and password hashing needs a dedicated library or Werkzeug's helper functions.
Frontend	Standard HTML, CSS, and JavaScript, or React (SRS-SR03)	React escapes text by default. Raw-HTML interfaces must not be used for user-supplied values (SEC-FR-19).
Database	MySQL or PostgreSQL (SRS-SR04)	Use the ORM or parameterized queries (SEC-FR-21) and a least-privilege application account.
ML library	Not specified (SRS-SR02)	Use the allow-listed algorithm registry (SEC-FR-15) and digest-checked artifacts (SEC-FR-23).
Deployment	Single server, local or cloud (SRS-SR05)	Reverse proxy, firewall, and production application server (SEC-NFR-07).

7.2 Controls by layer

Layer	Control	Requirements
Frontend	Render all user text as text; never insert user-supplied strings as HTML	SEC-FR-19
Frontend	Validate forms for usability only; the server validates again	SEC-FR-14
Frontend	Show generic messages; never display raw server responses	SEC-FR-24
Frontend	Keep credentials and session values out of URLs, logs, and browser storage readable by scripts	SEC-NFR-04

Layer	Control	Requirements
Frontend	Attach event handlers in code and avoid inline scripts, so that a strict Content Security Policy can be applied	SEC-NFR-09
Frontend	Show a notice on the upload page that datasets should not contain personal information	SEC-NFR-06
Backend	Deny by default: authentication middleware on every data route	SEC-FR-09
Backend	Ownership checks in the service layer, not repeated in individual route handlers	SEC-FR-10; SEC-NFR-10
Backend	Uniform login responses, hash computation for unknown identifiers, and throttling	SEC-FR-03, 04
Backend	Session regeneration at login, expiry, and server-side logout	SEC-FR-05, 07, 08
Backend	Anti-CSRF tokens when cookie sessions are used	SEC-FR-30
Backend	Schema validation, method allow-list, and response allow-list	SEC-FR-14, 29
Backend	Central error handler and redacted, structured logging	SEC-FR-24, 25
Backend	Job queue with concurrency and time limits	SEC-FR-28
ML logic	Algorithm registry; no dynamic imports	SEC-FR-15
ML logic	Fixed random seeds where the algorithm supports them	SRS-NFR06
ML logic	Metrics computed on the server only	SEC-FR-12
ML logic	Training in a separate process with memory and time limits	SEC-FR-28; SEC-NFR-05
ML logic	Artifacts saved with SHA-256 digests; only System-created artifacts are loaded	SEC-FR-23
Database	Parameterized queries or ORM	SEC-FR-21

Layer	Control	Requirements
Database	Application account limited to the privileges it needs; no schema changes at runtime	SEC-FR-21; SEC-NFR-01
Database	Owner identifier on every user object; foreign keys with cascading deletion	SEC-FR-10, 26
Database	Password hashes only; no plaintext password column	SEC-FR-02
Database	TLS for connections if the database runs on another host	SEC-NFR-02
File storage	Storage outside the web root with server-generated names	SEC-FR-18
File storage	Restrictive permissions owned by the service account	SEC-NFR-01
File storage	Optional per-user storage quota (proposed 500 MB) to limit abuse under T-08; not required by a SEC requirement	SEC-FR-17 (recommended)
File storage	Deletion routine that removes files together with their records	SEC-FR-26
Deployment	Non-root application account; firewall permits only web ports and restricted administrative access	SEC-NFR-07
Deployment	Reverse proxy request-size limit that matches SEC-FR-17 (for example, client_max_body_size in nginx)	SEC-FR-17
Deployment	TLS certificate for any non-local deployment	SEC-NFR-02
Deployment	Debug disabled; production application server	SEC-NFR-07
Deployment	Security headers set at the reverse proxy or application	SEC-NFR-09
Deployment	Log rotation with 30-day retention	SEC-NFR-11
Deployment	Scheduled retention job	SEC-NFR-06
Deployment	Secrets injected through environment variables	SEC-FR-27

Layer	Control	Requirements
Process	Lock files and dependency scans before submission and before each release	SEC-NFR-08
Process	Secret scan of the repository before each push	SEC-FR-27

7.3 Library options

The following are established options. The team selects among them and records the choice in the design document.

- Password hashing: argon2-cffi (Argon2id), bcrypt, or the built-in hasher of the selected framework.
- CSRF protection: Django's built-in middleware, or Flask-WTF with Flask.
- Session management: Django's session framework, or Flask-Login with Flask.
- Rate limiting: django-ratelimit with Django, or Flask-Limiter with Flask.
- Validation: Django forms and serializers, or Marshmallow or Pydantic with Flask.
- Dependency scanning: pip-audit for Python packages; npm audit for JavaScript packages.
- Secret scanning: gitleaks.
- Optional dynamic testing: OWASP ZAP baseline scan. TLS testing: testssl.sh.

8. Security Test Cases

The Actual result and Pass/Fail columns are intentionally blank because security testing has not yet been performed. Positive tests confirm required behavior; negative tests attempt misuse. Test data are examples and must be used only against the team's own test environment. Tests are grouped by area in Sections 8.1 to 8.6.

8.1 Authentication and sessions

Test Case ID	Requirement ID	Test scenario	Preconditions	Test steps	Test data	Expected result	Actual result	Pass/Fail
SEC-TC-01	SEC-FR-01	(Negative) Registration with a password below the minimum length	Application running; no account with the test identifier exists	1. Open the registration page. 2. Enter the identifier and password. 3. Submit. 4. Query the account table for the identifier.	Identifier: sec_user01; password: Ab1!xyz (7 characters)	HTTP 400 with a plain-language message stating the minimum length; no account row created		
SEC-TC-02	SEC-FR-01	(Negative) Registration with disallowed identifiers	Application running	1. Submit each identifier with the password Valid-Pass-2026. 2. Record each response.	Identifiers: x; admin'--; a 31-character identifier	Each request refused with HTTP 400; no account created		
SEC-TC-03	SEC-FR-01	(Positive) Registration and login with valid values	Application running	1. Register with valid values. 2. Log in with the same values. 3. Inspect the registration response.	Identifier: student_01; password: Valid-Pass-2026	Account created; login succeeds; registration response contains no password		
SEC-TC-04	SEC-FR-02	(Positive) Password stored as a salted hash	Two accounts registered with the same password	1. Inspect the stored value for each account. 2. Compare the two values. 3. Search the application logs for the password.	Password: Valid-Pass-2026	Neither stored value equals the password; the two values differ because of the salt; the value identifies an adaptive hash algorithm; the password does not appear in logs		

Test Case ID	Requirement ID	Test scenario	Preconditions	Test steps	Test data	Expected result	Actual result	Pass/Fail
SEC-TC-05	SEC-FR-03	(Negative) Account enumeration through login responses	Account student_01 exists	1. Log in as student_01 with a wrong password; record status and body. 2. Log in with an unknown identifier; record status and body. 3. Repeat each attempt 20 times; compare median response times.	Wrong password: Wrong-Pass-1; unknown identifier: nobody_xyz	Identical status (401) and message; median time difference below 50 ms		
SEC-TC-06	SEC-FR-04	(Negative) Login throttling	Account student_01 exists	1. Submit five wrong passwords for student_01. 2. Submit the correct password. 3. Wait 15 minutes; submit the correct password again.	Wrong-Pass-1 to Wrong-Pass-5; Valid-Pass-2026	Step 2 refused with HTTP 429; step 3 accepted		
SEC-TC-07	SEC-FR-05	(Positive) Session regenerated at login	Browser holds a pre-login session cookie	1. Record the cookie value C1. 2. Log in. 3. Record the new cookie value C2. 4. Send a protected request with C1.	Valid account credentials	C2 differs from C1; the request with C1 returns HTTP 401; entropy confirmed by code inspection (at least 128 bits)		

Test Case ID	Requirement ID	Test scenario	Preconditions	Test steps	Test data	Expected result	Actual result	Pass/Fail
SEC-TC-08	SEC-FR-06	(Positive) Cookie attributes	HTTPS deployment for the Secure flag; localhost for the other attributes	1. Log in. 2. Inspect the Set-Cookie header in browser developer tools.	Valid account credentials	Cookie carries HttpOnly, SameSite=Lax or Strict, and Secure (HTTPS deployment). If token authentication is used, the design document states the storage location		
SEC-TC-09	SEC-FR-07	(Negative) Idle timeout	Test configuration sets the idle timeout to 1 minute (production value: 30 minutes)	1. Log in. 2. Wait 61 seconds without activity. 3. Request a protected page.	Valid account credentials	HTTP 401; login page shown; the old credential is no longer accepted		
SEC-TC-10	SEC-FR-08	(Negative) Credential reuse after logout	Logged in; session cookie recorded	1. Log out. 2. Send a protected request with the recorded cookie.	Recorded session cookie	HTTP 401		

8.2 Authorization and isolation

Test Case ID	Requirement ID	Test scenario	Preconditions	Test steps	Test data	Expected result	Actual result	Pass/Fail
SEC-TC-11	SEC-FR-09; SEC-FR-29	(Negative) Unauthenticated access to every data endpoint	API specification available	1. Without a session, call each data endpoint with GET, POST, and DELETE. 2. Use the identifiers 1, 2, and a random UUID.	Identifiers: 1; 2; random UUID	Every call returns HTTP 401; no response contains user data		

Test Case ID	Requirement ID	Test scenario	Preconditions	Test steps	Test data	Expected result	Actual result	Pass/Fail
SEC-TC-12	SEC-FR-10	(Negative) Cross-user object access	Users A and B each own one dataset, one model, one result, and one report	1. Log in as B. 2. Using A's identifiers, call preview, train, result, model download, report download, and delete. 3. Log in as A and confirm that A's objects are unchanged.	A's object identifiers	Each call returns HTTP 404 with the same body as for a nonexistent identifier; A's objects are unchanged		
SEC-TC-13	SEC-FR-11	(Negative) Listing and comparison isolation	Users A and B each have two trained models	1. Log in as B and request the dataset and model lists. 2. Submit a comparison containing one of A's model identifiers and one of B's.	A's model identifier; B's model identifier	Lists contain only B's objects; comparison refused in full (HTTP 404 or 400); no metrics for A's model in any response		
SEC-TC-14	SEC-FR-12	(Negative) Client-supplied metric values	Dataset loaded and split configured	1. Send a training request with an extra field accuracy set to 1.0. 2. Read the stored result.	accuracy: 1.0	The field is ignored or refused with HTTP 400; the stored accuracy equals the server-computed value		
SEC-TC-15	SEC-FR-13	(Negative) Administrative functions for a standard user	Logged in as a standard user	1. Request /admin and /api/admin/users. 2. Review the API specification for cross-user functions.	Paths listed	Each request returns HTTP 404 or 403; the specification lists no cross-user function		

8.3 Input validation and file handling

Test Case ID	Requirement ID	Test scenario	Preconditions	Test steps	Test data	Expected result	Actual result	Pass/Fail
SEC-TC-16	SEC-FR-14	(Negative) Server-side parameter validation	Logged in; dataset loaded	1. Send training requests with one invalid parameter at a time.	Split ratio 150; split ratio -5; split ratio abc; target column x'; DROP TABLE users; --	Each request refused with HTTP 400 and a plain-language message; no training job created		
SEC-TC-17	SEC-FR-15	(Negative) Algorithm identifier outside the registry	Logged in	1. Send training requests with unregistered algorithm identifiers. 2. Check the logs for any import or execution attempt.	os.system; sklearn.linear_model.LogisticRegression; **import**('os')	Each request refused with HTTP 400; no import or execution recorded		

Test Case ID	Requirement ID	Test scenario	Preconditions	Test steps	Test data	Expected result	Actual result	Pass/Fail
SEC-TC-18	SEC-FR-16	(Negative) Binary or malformed files named .csv	Logged in	1. Upload a renamed .xlsx workbook. 2. Upload a file beginning with %PDF. 3. Upload a file with invalid UTF-8 bytes. 4. Upload a file containing a row with more fields than the header.	Renamed Excel workbook; PDF content with a .csv name; Latin-1 text with byte 0xE9; ragged CSV	Each file refused with HTTP 400 and the plain-language message; nothing stored		
SEC-TC-19	SEC-FR-17	(Boundary, negative and positive) Size and structure limits	Logged in; limits as configured	1. Upload 10,485,760 bytes plus 1 byte. 2. Upload exactly 10,485,760 bytes of valid CSV. 3. Upload datasets with 19 rows and with 20 rows. 4. Upload a dataset with 501 columns.	CSV files of the stated sizes and shapes	Step 1: HTTP 413. Step 2: accepted. Step 3: 19 rows refused under SRS-DR09; 20 rows accepted. Step 4: HTTP 400		
SEC-TC-20	SEC-FR-18	(Negative) Path traversal and overwrite	Logged in; storage location known	1. Upload a CSV named ../../../evil.csv. 2. Upload two different files, both named data.csv. 3. Inspect the storage directory and the database.	File names: ../../../evil.csv; data.csv (twice, with different contents)	No file written outside the storage directory; two distinct server-generated stored names; original names kept only as metadata; no overwrite		
SEC-TC-21	SEC-FR-19	(Negative) Script payloads in dataset content	Logged in	1. Upload a CSV whose header and one cell contain HTML and script payloads. 2. Open the dataset preview. 3. Open the evaluation view for a trained model. 4. Inspect the DOM.	Header: <img src=x onerror=alert(1)> ; cell: <script>alert(1) </script>	Text displayed literally; no alert; no script element created in the DOM		
SEC-TC-22	SEC-FR-20	(Negative) Markup in PDF report	Report generated for a dataset whose columns are named as in the test data	1. Generate the report. 2. Extract text from the PDF. 3. Open the PDF in a reader and check for active content.	Column names: Score (100%) bold; dataset name: report_test	Special characters appear literally in the extracted text; no active content; the document opens without error		

Test Case ID	Requirement ID	Test scenario	Preconditions	Test steps	Test data	Expected result	Actual result	Pass/Fail
SEC-TC-23	SEC-FR-21	(Negative) SQL injection	Logged in; at least one dataset exists	1. Submit the login form with the payload identifier. 2. Request a dataset using each payload as its identifier. 3. Inspect responses for SQL error text. 4. Confirm that table contents are unchanged.	Login identifier: ' OR '1'='1' --; ID values: 1 OR 1=1; 1; DROP TABLE datasets	No successful login; each ID treated as a literal (HTTP 400 or 404); no SQL error text; records unchanged		

8.4 Downloads and artifacts

Test Case ID	Requirement ID	Test scenario	Preconditions	Test steps	Test data	Expected result	Actual result	Pass/Fail
SEC-TC-24	SEC-FR-22	(Negative) Unauthorized and traversal download requests	User A has a trained model; user B is logged in	1. As B, request A's model by identifier. 2. As B, request a model using the identifier ../../config. 3. Without a session, request any model.	A's model identifier; ../../config; any identifier	Step 1: HTTP 404. Step 2: HTTP 400 or 404, with no file returned. Step 3: HTTP 401		
SEC-TC-25	SEC-FR-22	(Positive) Owner download with required headers	User A has a completed model and a report	1. Log in as A. 2. Download the model and the report. 3. Compute SHA-256 values and compare them with the recorded digest. 4. Inspect response headers and file names.	A's model and report	Digests match; headers match SEC-FR-22(d); file names contain only permitted characters		

Test Case ID	Requirement ID	Test scenario	Preconditions	Test steps	Test data	Expected result	Actual result	Pass/Fail
SEC-TC-26	SEC-FR-23	(Negative) Tampered model artifact	User A's model is complete and its digest is recorded	1. Append one byte to the stored model file using the file system. 2. Request a download. 3. Request reuse of the model for prediction, if the design supports reuse (SRS-SR09). 4. Check the log.	One appended byte	Download and reuse refused with a plain-language message; integrity failure logged		

8.5 Errors, logging, configuration, and deletion

Test Case ID	Requirement ID	Test scenario	Preconditions	Test steps	Test data	Expected result	Actual result	Pass/Fail
SEC-TC-27	SEC-FR-24	(Negative) Generic error responses	Test environment with debug disabled	1. Make the database unreachable in the test environment and submit a request. 2. Submit a training request with a missing target column. 3. Inspect both response bodies and the server log.	Target column: Result_X (not in dataset)	Step 1: HTTP 500 with a generic message; no stack trace or SQL text in the response; details in the server log. Step 2: plain-language message naming the missing column; no internals		
SEC-TC-28	SEC-FR-25; SEC-NFR-04	(Positive) Audit events recorded without secrets	Logging enabled	1. Perform once each: registration, failed login, successful login, logout, unauthorized access, upload, training, download, and deletion. 2. Inspect the log. 3. Search the log for the password and session values.	Test account data	Each event has the required fields; the search finds no password or session value		

Test Case ID	Requirement ID	Test scenario	Preconditions	Test steps	Test data	Expected result	Actual result	Pass/Fail
SEC-TC-29	SEC-FR-26	(Positive) Cascading deletion	User A has a dataset, a model, a result, and a report	1. Delete the dataset as A. 2. Query the database for all four objects. 3. Check the storage directory. 4. Request a download of the deleted model.	Not applicable	Database records removed; stored files removed; download returns HTTP 404; deletion logged		
SEC-TC-30	SEC-FR-27	(Negative) Secret exposure	Repository, built frontend, and deployed site available	1. Search the repository and built frontend for the secret key and database password. 2. Request /.env, /config.py, and /.git/config from the browser. 3. Confirm that the application reads secrets from the environment.	Known test secret values	No matches in tracked files or the frontend bundle; requests return HTTP 404 or 403; secrets read from the environment		
SEC-TC-31	SEC-FR-28	(Negative) Concurrency and time limits	Test configuration sets the time limit to 10 seconds (production: 10 minutes)	1. As A, start two training jobs. 2. As B, start one job while A's first job is running. 3. Start a job that exceeds the time limit.	Maximum-size dataset for step 3	Step 1: second job refused (HTTP 429) or queued. Step 2: accepted within the system-wide limit of two. Step 3: terminated and reported as failed in plain language		
SEC-TC-32	SEC-FR-29	(Negative) Method and response restrictions	Logged in	1. Send PUT, PATCH, and DELETE to endpoints that accept only GET and POST. 2. Inspect the dataset list and result responses for prohibited fields.	Not applicable	Unsupported methods return HTTP 405; no password hash, storage path, or other user identifier in any response		
SEC-TC-33	SEC-FR-30	(Negative) Cross-site request forgery	User A logged in; test page hosted on a different origin	1. Open a test page from another origin that auto-submits forms to the upload, train, and delete endpoints. 2. Check user A's data.	Auto-submitting forms targeting the System's endpoints	Each request refused (HTTP 401 or 403); no data changed		

Test Case ID	Requirement ID	Test scenario	Preconditions	Test steps	Test data	Expected result	Actual result	Pass/Fail
SEC-TC-34	SEC-FR-31	(Negative and positive) Cross-origin access	Frontend and backend on separate origins in the test setup	1. Send an API request with an Origin header from an unlisted site. 2. Send a request with the configured frontend origin. 3. Inspect Access-Control-Allow-Origin in each response.	Origin: https://unlisted.example; configured frontend origin	Step 1: no allow header for the unlisted origin. Step 2: only the configured origin is echoed. No wildcard is sent with credentials		
SEC-TC-35	SEC-FR-32	(Negative; conditional) Formula injection in CSV export	CSV export implemented; if not implemented, record as not applicable	1. Create a dataset with a column named =HYPERLINK(http://example.com). 2. Select that column as the target, train a model, and export the results to CSV. 3. Open the export in a text editor and check the first character of each cell.	Column name: =HYPERLINK(http://example.com)	Formula-leading characters neutralized with an apostrophe or equivalent		

8.6 Infrastructure and quality attributes

Test Case ID	Requirement ID	Test scenario	Preconditions	Test steps	Test data	Expected result	Actual result	Pass/Fail
SEC-TC-36	SEC-NFR-01	(Negative) Storage permissions	Storage directory deployed; a second operating-system account exists	1. Inspect the permissions of the storage directory and its files. 2. Attempt to read a stored dataset as the second account.	Not applicable	Directory mode 0700 (or equivalent); files 0600 or 0640; read attempt denied		
SEC-TC-37	SEC-NFR-02	(Negative; conditional) Plain HTTP and TLS versions	Non-local deployment with TLS configured; if the System is local-only, record as not applicable	1. Request the http:// address. 2. Run a TLS test tool such as testssl.sh.	Not applicable	Step 1: redirect to HTTPS or refused. Step 2: TLS 1.0 and 1.1 rejected; TLS 1.2 or later accepted		

Test Case ID	Requirement ID	Test scenario	Preconditions	Test steps	Test data	Expected result	Actual result	Pass/Fail
SEC-TC-38	SEC-NFR-03	(Negative) Integrity of stored data	User A has a dataset and an evaluation result	1. Change one byte of the stored dataset file. 2. Request training on that dataset. 3. Change a metric value directly in the database. 4. Request the result.	Not applicable	Steps 2 and 4 refused with plain-language errors because digests do not match; both events logged		
SEC-TC-39	SEC-NFR-04	(Negative) Credentials in URLs and logs	Logged in	1. Submit the login form; record the browser address bar and history. 2. Search client and server logs for the password and session values.	Valid account credentials	No credential or session value in URLs, redirects, or logs		
SEC-TC-40	SEC-NFR-05	(Positive) Responsiveness during training	One training job on a maximum-size dataset is running	1. Start training. 2. Measure home-page response time over 20 requests from a client on the target network.	Maximum permitted dataset	95th percentile at or below 2 seconds (proposed)		
SEC-TC-41	SEC-NFR-06	(Positive) Retention cleanup	Test configuration sets retention to 1 day	1. Create a dataset and a result for user A, and a dataset for user B. 2. Set A's last-login date two days back in the test database; leave B's current. 3. Run the cleanup job. 4. Check the database, storage, and log.	Not applicable	A's expired dataset, models, results, and reports removed; each removal logged; B's dataset remains intact		

Test Case ID	Requirement ID	Test scenario	Preconditions	Test steps	Test data	Expected result	Actual result	Pass/Fail
SEC-TC-42	SEC-NFR-07	(Negative) Debug and default configuration	Deployed configuration	1. Request a nonexistent path and an error-inducing URL. 2. Check the responses for debugger pages or stack traces. 3. Inspect the debug setting and the server software. 4. Request a static directory.	Not applicable	No debugger or stack trace; debug setting off; production application server in use; directory listing returns HTTP 403 or 404; default credentials absent		
SEC-TC-43	SEC-NFR-08	(Positive) Dependency vulnerability scan	Lock files present	1. Run pip-audit against the Python lock file and npm audit against the JavaScript lock file. 2. Record findings. 3. Confirm that each High or critical finding is fixed or justified.	Not applicable	Lock files present; no unresolved High or critical findings, or each has a documented justification		
SEC-TC-44	SEC-NFR-09	(Positive) Security headers	Application running locally or deployed	1. Request an HTML page and an API endpoint using curl -I or browser developer tools. 2. Check the headers.	Not applicable	All headers listed in SEC-NFR-09 present with the specified values		

Test Case ID	Requirement ID	Test scenario	Preconditions	Test steps	Test data	Expected result	Actual result	Pass/Fail
SEC-TC-45	SEC-NFR-10	(Positive; inspection) Reuse of shared security controls	Release-candidate code base	1. Add a test endpoint that uses the shared authentication and ownership mechanism. 2. Register a test algorithm in the registry. 3. Confirm both work without new security code in the route or controller. 4. Remove the test code.	Test endpoint and test algorithm	The endpoint is protected by the shared mechanism; the algorithm is available without changes to controller code		
SEC-TC-46	SEC-NFR-11	(Negative) Log access and retention	Log directory in place	1. Request the log file through the browser. 2. Check the log file permissions. 3. Check the rotation setting.	Not applicable	Web request returns HTTP 403 or 404; permissions restricted to the service account; retention configured as 30 days		
SEC-TC-47	SEC-NFR-12	(Positive) Cross-browser consistency	Latest Chrome, Firefox, and Edge installed	1. Repeat SEC-TC-08, SEC-TC-33, and SEC-TC-44 in each browser. 2. Record browser versions.	Not applicable	Same results in all three browsers		

9. Security Risk Assessment

9.1 Rating scheme

Ratings are inherent. They describe the risk before the controls in Section 5 are implemented.

- Likelihood. Low: requires special skill, unusual conditions, or prior access. Medium: exploitable with common tools, or by a user on the same network. High: exploitable with freely available tools, or the weakness is common in typical student implementations.
- Impact. Low: minor disclosure or cosmetic effect, with no personal data. Medium: compromise or disruption affecting one user's data, or the service for a limited period. High: compromise of other users' data, credentials, or server control, or prolonged loss of service.
- Risk level. The score is the likelihood value multiplied by the impact value, where Low = 1, Medium = 2, and High = 3. Scores of 1 or 2 are Low; scores of 3 or 4 are Medium; scores of 6 or 9 are High.

The matrix below gives the resulting risk level (likelihood in rows, impact in columns).

Likelihood / Impact	Low	Medium	High
High	Medium	High	High
Medium	Low	Medium	High
Low	Low	Low	Medium

- Priority. P1: implement and test before submission. P2: implement before submission if time allows; otherwise document as an accepted risk with justification. P3: implement if the effort is low; otherwise document.

9.2 Risk register

Risk ID	Threat	Likelihood	Impact	Risk level	Mitigation	Priority
R-01	T-01 Unauthenticated access to data endpoints	Medium	High	High	SEC-FR-09, 29; deny-by-default routing; verified by SEC-TC-11	P1
R-02	T-02 Brute-force login	High	Medium	High	SEC-FR-01, 03, 04; verified by SEC-TC-05, 06	P1
R-03	T-03 Credential interception on an untrusted network	Medium	High	High	SEC-NFR-02, SEC-FR-06, SEC-NFR-04; a localhost-only demonstration lowers the likelihood to Low	P1

Risk ID	Threat	Likelihood	Impact	Risk level	Mitigation	Priority
R-04	T-04 Session fixation, hijacking, and persistence after logout	Medium	High	High	SEC-FR-05, 07, 08; verified by SEC-TC-07, 09, 10	P1
R-05	T-05 Cross-user object access	High	High	High	SEC-FR-10, 11, 12; verified by SEC-TC-12, 13, 14	P1
R-06	T-06 Malformed or malicious CSV content	High	Medium	High	SEC-FR-16, 17, 24; verified by SEC-TC-18, 19, 27	P1
R-07	T-07 Path traversal and file overwrite	Low	High	Medium	SEC-FR-18, 22; verified by SEC-TC-20, 24	P2
R-08	T-08 Resource exhaustion and denial of service	Medium	Medium	Medium	SEC-FR-17, 28; SEC-NFR-05; verified by SEC-TC-31, 40	P2
R-09	T-09 SQL injection	Low	High	Medium	SEC-FR-21; verified by SEC-TC-23	P2
R-10	T-10 Cross-site scripting	Medium	Medium	Medium	SEC-FR-19, 20; SEC-NFR-09; verified by SEC-TC-21, 22, 44	P2
R-11	T-11 Cross-site request forgery	Low	Medium	Low	SEC-FR-30, SEC-FR-06; verified by SEC-TC-33	P3
R-12	T-12 Excessive API exposure and permissive CORS	Medium	Medium	Medium	SEC-FR-29, 31; verified by SEC-TC-32, 34	P2
R-13	T-13 Information disclosure through error messages	High	Low	Medium	SEC-FR-24; debug disabled under SEC-NFR-07; verified by SEC-TC-27, 42	P2
R-14	T-14 Credentials or data in logs; unauthorized log access	Medium	Medium	Medium	SEC-FR-25; SEC-NFR-04, 11; verified by SEC-TC-28, 39, 46	P2
R-15	T-15 Unauthorized access to models and reports	Medium	Medium	Medium	SEC-FR-22, 10; SEC-NFR-01; rises to High if storage is web-accessible; verified by SEC-TC-24, 36	P2
R-16	T-16 Unsafe deserialization of model artifacts	Low	High	Medium	SEC-FR-23, 15; SEC-NFR-03; verified by SEC-TC-17, 26, 38	P2
R-17	T-17 Vulnerable third-party components	Medium	Medium	Medium	SEC-NFR-08; verified by SEC-TC-43	P2

Risk ID	Threat	Likelihood	Impact	Risk level	Mitigation	Priority
R-18	T-18 Security misconfiguration and secret exposure	High	High	High	SEC-FR-27; SEC-NFR-07, 09; verified by SEC-TC-30, 42, 44	P1
R-19	T-19 Incomplete deletion and excessive retention	Medium	Low	Low	SEC-FR-26; SEC-NFR-06; verified by SEC-TC-29, 41	P3
R-20	T-20 CSV formula injection in exports	Low	Low	Low	SEC-FR-32; verified by SEC-TC-35	P3

9.3 Residual risk

After the P1 and P2 controls are implemented and the tests in Section 8 pass, the principal residual risks are: a determined external denial-of-service attack against a single server (LM-02); secrets committed to the repository, or configuration weakened after testing, which only process controls can prevent; and vulnerabilities in third-party components disclosed after the last scan, which SEC-NFR-08 addresses by rescanning before each release. These residual risks are accepted for a university demonstration project.

10. Security Assumptions, Constraints, and Limitations

10.1 Assumptions

ID	Assumption
AS-01	The System runs on one server operated by the team, with a dedicated operating-system account for the application (SRS-SR05).
AS-02	The team selects its stack from the options in Section 7.1. The requirements apply to all of them.
AS-03	Users are students or course participants. The SRS defines no administrative role (SEC-FR-13).
AS-04	Uploaded datasets may contain personal information about third parties. The System does not detect personal data.

ID	Assumption
AS-05	Users access the System with the modern browsers named in SRS-SR06.
AS-06	Campus and public networks are untrusted, and traffic may be observed by others on the same network.
AS-07	The team controls the development environment, the version-control repository, and the server.
AS-08	Model artifacts are created only by the System's own training process.

10.2 Constraints

ID	Constraint
CN-01	The schedule and team size are typical of a university mini-project. No external penetration test is planned.
CN-02	Hardware resembles college lab machines or basic cloud instances (SRS-SR07), which limits dataset size and concurrency.
CN-03	Security testing uses manual methods and free tools.
CN-04	Values marked proposed are not SRS values and must be confirmed (Section 10.4).

10.3 Limitations and exclusions

ID	Limitation
LM-01	No multi-factor authentication, email verification, or password reset. The SRS does not require them.

ID	Limitation
LM-02	No protection against distributed denial-of-service attacks, and no web application firewall or content delivery network.
LM-03	Encryption at rest is not required. Operating-system disk encryption is recommended where available.
LM-04	Privacy attacks on trained models, such as membership inference and model inversion, are out of scope.
LM-05	Uploads are not scanned for malware. CSV files are parsed as text and never executed.
LM-06	No backup, disaster recovery, or high availability, because the SRS specifies a single server (SRS-SR05).
LM-07	Security logs remain on the server, with no central log management or alerting.
LM-08	A localhost-only demonstration uses HTTP. This exception applies only to that setting; any network-reachable deployment must meet SEC-NFR-02.
LM-09	No formal regulatory or compliance assessment is performed.

10.4 Open decisions for the team

Decision	Proposed value	Affects
Maximum upload size	10 MB	SEC-FR-17
Row and column limits	100,000 rows; 500 columns	SEC-FR-17
Field length limit	1,000 characters	SEC-FR-17
Login throttling	5 failures in 15 minutes; 20 requests per minute per address	SEC-FR-04

Decision	Proposed value	Affects
Session timeouts	30 minutes idle; 8 hours absolute	SEC-FR-07
Training limits	1 job per user; 2 system-wide; 10-minute time limit	SEC-FR-28
Data retention	90 days after the owner's last login	SEC-NFR-06
Log retention	30 days	SEC-NFR-11
Session mechanism	Cookie-based sessions or token-based authentication	SEC-FR-06, 30
Deployment scope	Localhost only, or network-reachable with TLS	SEC-NFR-02